Web Application Penetration Testing Report

25th February, 2025

(Closure Report)

1.1 Copyright

The copyright in this work is vested in Cybertryzub Infosec Pvt. Ltd., and the document is issued in confidence for the purpose for which it is supplied. It must not be reproduced in whole or in part or used for tendering or manufacturing purposes except under agreement or with the consent in writing of Cybertryzub Infosec Pvt. Ltd. and then only on condition that this notice is included in any such reproduction. No information as to the contents or subject matter of this document or any part thereof arising directly or indirectly there from shall be given orally or in writing or communicated in any manner whatsoever to any third party being an individual firm or company or any employee thereof without the prior consent in writing of Cybertryzub Infosec Pvt. Ltd.

© Cybertryzub Infosec Pvt. Ltd.

1.2 Contact Information

Mrs. Jyoti Singh
CISA, CIPM, FIP, CIPP/E, ISO 27001
LA, DevOps, MSc, PG Data Science.
(InfoSec Lead Auditor)
+91 9873784553, 8295777275
info@cybertryzub.com

Corporate Office
PLOT NO 76D UDYOG VIHAR 4 SECTOR 18,
GURGAON – 122001
HARYANA, India

Registered Office
F-300, SECTOR 63, NOIDA-201301
UTTAR PRADESH, INDIA

2.0 About Us

Cybertryzub InfoSec Private Limited is an ISO Certified (ISO 27001:2013) company. Cybertryzub aims to provide Auditing; Consulting, Information Risk Management and Managed services tailored as per the market requirements and enhance the satisfaction and confidence index of its existing and potential customers.

Cybertryzub has been a CERT-In empaneled IT Security Auditor. It is an acknowledgement of Cybertryzub's technical expertise in conducting Information Security Audits. As a CERT-In empaneled auditor Cybertryzub is qualified to conduct security audits of websites, networks & applications. On successfully completing the audit as per CERT-In Guidelines, our team can issue the CERT-In Certification as required by compliance requirements.

From the development of a Security Policy, Security Awareness Training, through to the delivery of complete end-to-end solutions that encompass Perimeter Security, Secure Content Management, Identity and Access Management, Vulnerability Assessment, Risk, Policy and Compliance Management, Cybertryzub InfoSec Private Limited helps organizations understand, monitor and mitigate the risks in their IT infrastructure.

Cybertryzub InfoSec Private Limited has information security experts, compliance professionals and process consultants from different industry verticals with multiple certifications each with experience in handling consulting assignments, audits and training programs.

Cybertryzub InfoSec Consultants has established a reputation for providing practical solutions that are both businesses driven and cost-effective. This has enabled the company to secure the IT Infrastructure of leading Stock Brokers, Government undertakings, Banks, Insurance Companies and Financial Institutions, BPO, KPO, PKI Industry, Data Center, Software Company, Automobile, Healthcare & Life Sciences, Hospitality, Travel, Transportation, Consumer & Retail, Technology, Media & Telecommunication, School, College, Smart City. Security Leadership our experienced team of ethical hackers have identified security vulnerabilities, we have put together a highly qualified team of security researchers with credentials like CISA, CISSP, OSCP, CSOE, CCNP, MCSE+, ISO 27001 LA, ITIL, COBIT, CIPP/E, CIPM, FIS, DISA, CPA, Cyber Law, Data Science, Artificial Intelligence & Machine Learning, DevSecOps, AWS Architect, Azure Architect.

3.0 Table of Contents

1.0 1.1 Copyright 2
1.2 Contact Information.....2
2.0 About Us.....3
3.0 Table of Contents.....4
4.0 Assessment Information.....5
4.1 Assessment scope summary.....5
4.2 Client details.....5
4.3 Cybertryzub Infosec Pvt. Ltd. Details.....5
5.0 Engagement Overview.....6
6.0 Process and Methodology.....7
7.0 Vulnerability Overview.....8
8.0 Checklist.....9
9.0 Test Execution Summary.....13
10.0 Executive Summary.....14
11.0 Summary ..vulnerabilities.....15
12.0 Detailed Findings and Recommendation.....16
13.0 High-Level Recommendations.....45

4.0 Assessment Information

4.1 Assessment Scope Summary

Engagement Type	Web application Gray Box Assessment
Engagement Scope	https://preprod.jupiter.crego.io
Engagement Timeframe	September 5th, 2024 to February 25th, 2025

4.2 Client Details

Organization	Kiranovations Technologies Private Limited (Crego)
Contact Person	Abhishek Sharma
Email id	abhishek@crego.io
Telephone:	9599976692

4.3 Cybertryzub Infosec Pvt. Ltd. Details

Auditor	Mr. Deepanshu Kumar
Review and Final Approval	Mr. Shubham Raj Mourya
Report ID:	
Report Type	Level 2 Web Application Report

5.0 Engagement Overview

Kiranovations Technologies Private Limited (Crego) has engaged with **Cybertryzub** to conduct a penetration test of their **Web Application**. This report contains all the results of the report as well as all the action items that were included in the penetration test. The purpose of this report is to present the current security level of the external perimeters including gaps, vulnerabilities, and misconfigurations. The findings presented in this report should be fixed to improve the security level of the network systems.

Service Description

Web application Vulnerability Assessment and Penetration Testing (VAPT) is the process of simulating real-world attacks by using the same techniques as malicious hackers. For a security assessment that goes beyond a simple vulnerability scanner, you need experts in the industry. **Cybertryzub** conducts its penetration test by approaching the scope with both a manual and automatic approach.

Web Application Penetration Test

our application-level penetration testing consists of both unauthenticated and authenticated testing using both automated and manual methods with particular emphasis placed on identifying vulnerabilities associated with the OWASP Top 10 Most Critical Application Vulnerabilities. It is important to note that a penetration test is not just an automated vulnerability scan, and a large portion of web application penetration testing is a manual process with a skilled engineer attempting to identify, exploit, and evaluate the associate risk of security issues.

Project Objectives

Cybertryzub consultants conduct all testing manually combined with custom and commercial tools that perform unique attack approaches on the network to make sure we cover the whole system in the test. Our expert knowledge and experience are the value we provide in our services.

6.0 Process and Methodology

Cybertryzub has developed a proven Vulnerability Assessment/Penetration Testing Methodology (illustrated below) from best practices including the Open-Source Security Testing Methodology Manual (OSSTMM), the Council for Registered Ethical Security Testers (CREST), the Penetration Testing Execution Standard (PTES), and our 15 plus years of experience. We have also scaled the methodology to account for differing risks and preferred engagement modalities to ensure that we can provide the right testing and assurance at the right cost.

1 Reconnaissance

This process begins with a detailed scanning and enumeration of the network system and infrastructure, and the information related to the system that is exposed on the internet. After this stage, we conduct manual testing of the gathered data to be analyzed further for attack paths.

2 Automated Approach

Once the scope has been fully enumerated, we start to approach the scope manually and with automatic approaches both self-developed and commercial. The goal is to cover most of the network.

3 Exploitation And Manual Testing

At this stage of the assessment, our experts review the gathered attack vectors and try to exploit the vulnerabilities found in a manual safely approach.

4 Assessment Report

Once the engagement has been completed, we start to develop the assessment report which consists of an executive part and a technical part where we present all the findings and recommendations for fix.

5 Re-test

As an additional option to our standard assessment, we offer a full re-test to our clients to check whether the issues has been fixed by the client and if it’s possible to bypass the patches that were implemented. This will then be updated by a new re-test report

7.0 Vulnerability Overview

Cybertryzub performed a Web Application Security Assessment for **Kiranovations Technologies Private Limited (Crego)** on **05-09-2024** to **25-02-2025**. This assessment utilized both commercial and proprietary tools for the initial mapping and reconnaissance of the network system as well as custom tools and scripts for unique vulnerabilities. Several attacking tools was used in order to conduct the penetration testing on the network.

VULNERABILITY RISK DEFINITION AND CRITERIA

The risk rating assigned to each vulnerability are determined by averaging several aspects of the exploit and the environment, including reputation, difficulty and impact.

Critical — Critical vulnerabilities pose a serious threat to an organization's security, and should be fixed immediately. They may provide a total compromise of the target environment, or similar critical impacts.

High — High risk vulnerabilities provide a serious risk to the company environment and should be corrected promptly. These issues can significantly affect the organization's security posture.

Medium — Medium severity vulnerabilities represent a moderate risk to the environment. They may require additional context before remediation but should be remediated after critical and high risks.

Low — Low severity vulnerabilities provide minimal risk to the target environment, and often theoretical in nature. Remediation of low risks is often a lower priority than other security hardening techniques.

Informational — Informational vulnerabilities have little-or-no impact to the target scope by themselves. They are included however, as they may be a risk when combined with other circumstances or technologies not currently in place. Remediation of informational items is not necessary.

8.0 Checklist

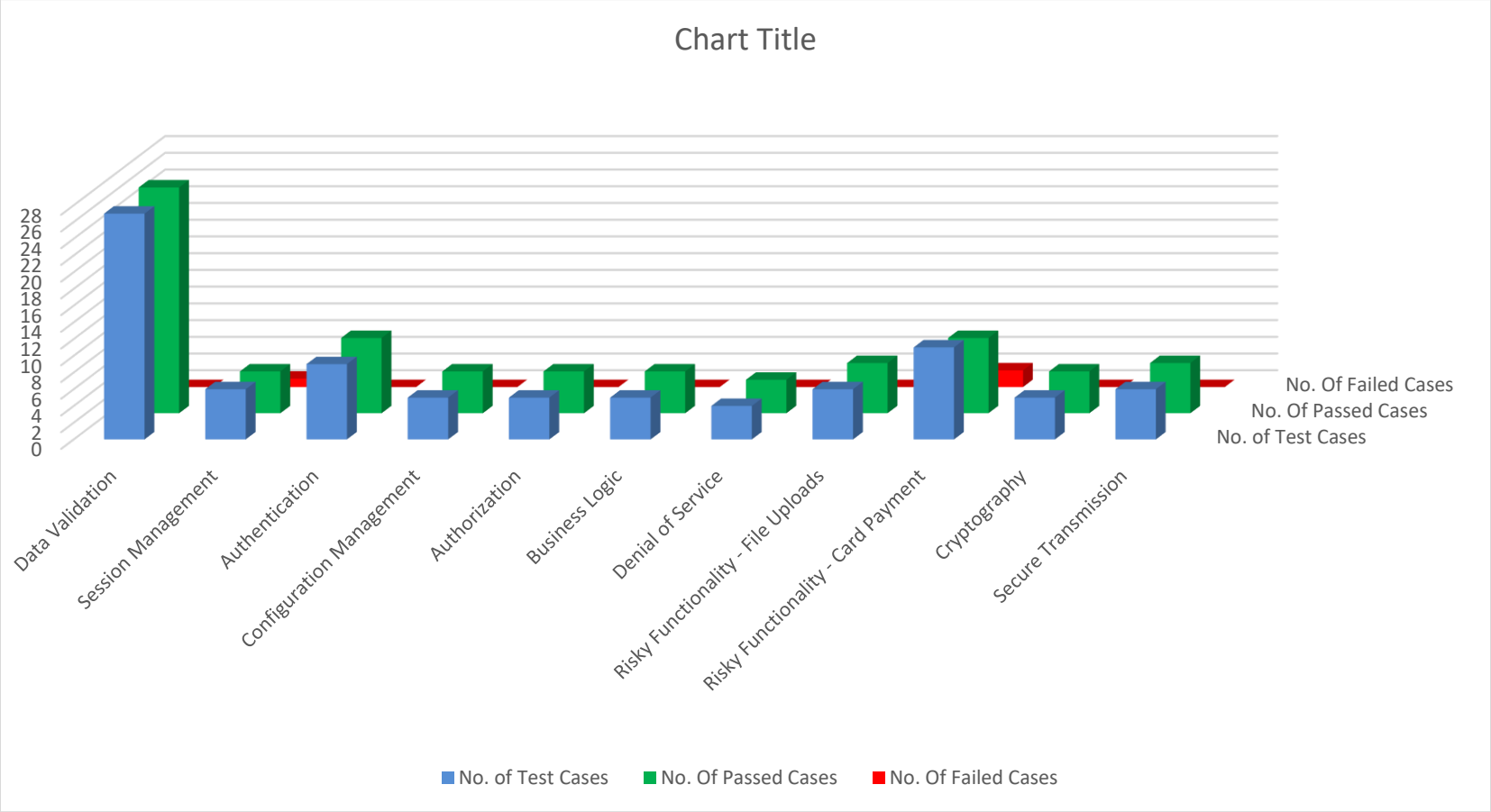
Cybertryzub Web Application Security Testing Checklist		
	Objective	**Test Outcome**
	Data Validation	
	✓ Test for Reflected Cross Site Scripting ✓ Test for Stored Cross Site Scripting ✓ Test for DOM based Cross Site Scripting ✓ Test for Cross Site Flashing ✓ Test for HTML Injection ✓ Test for SQL Injection ✓ Test for LDAP Injection ✓ Test for ORM Injection ✓ Test for XML Injection ✓ Test for XXE Injection ✓ Test for SSI Injection ✓ Test for XPath Injection ✓ Test for XQuery Injection ✓ Test for IMAP/SMTP Injection ✓ Test for Code Injection ✓ Test for Expression Language Injection ✓ Test for Command Injection ✓ Test for Overflow (Stack, Heap and Integer) ✓ Test for incubated vulnerabilities ✓ Test for HTTP Splitting/Smuggling Test for HTTP Verb Tampering ✓ Test for Open Redirection ✓ Test for Local File Inclusion ✓ Test for Remote File Inclusion ✓ Compare client-side and server-side validation rules Test for NoSQL injection ✓ Test for HTTP parameter pollution Test for auto-binding ✓ Test for Mass Assignment ✓ Test for NULL/Invalid Session Cookie	Not Found

	Session Management	
	✓ Establish how session management is handled in the application (eg, tokens in cookies, token in URL) Check session tokens for cookie flags (httpOnly and secure) ✓ Check session cookie scope (path and domain) Check session cookie duration (expires and max-age) Check session termination after a maximum lifetime Check session termination after relative timeout Check session termination after logout ✓ Test to see if users can have multiple simultaneous sessions Test session cookies for randomness ✓ Confirm that new session tokens are issued on login, role change and logout ✓ Test for consistent session management across applications with shared session management Test for session puzzling ✓ Test for CSRF and clickjacking	Not Found
	Authentication	
	✓ Test for user enumeration Test for authentication bypass Test for bruteforce protection Test password quality rules Test remember me functionality ✓ Test for autocomplete on password forms/input Test password reset and/or recovery ✓ Test password change process Test CAPTCHA ✓ Test multi factor authentication ✓ Test for logout functionality presence ✓ Test for cache management on HTTP (eg Pragma, Expires, Max-age) Test for default logins ✓ Test for user-accessible authentication history ✓ Test for out-of channel notification of account lockouts and successful password changes ✓ Test for consistent authentication across applications with shared authentication schema / SSO	Not Found
	Configuration Management	
	✓ Check for commonly used application and administrative URLs Check for old, backup and unreferenced files ✓ Check HTTP methods supported and Cross Site Tracing (XST) Test file extensions handling ✓ Test for security HTTP headers (e.g. CSP, X-Frame-Options, HSTS) Test for policies (e.g. Flash, Silverlight, robots) ✓ Test for non-production data in live environment, and vice-versa ✓ Check for sensitive data in client-side code (e.g. API keys, credentials)	Not Found
	Authorization	

	✓ Test for path traversal ✓ Test for bypassing authorization schema ✓ Test for vertical Access control problems (a.k.a. Privilege Escalation) ✓ Test for horizontal Access control problems (between two users at the same privilege level) ✓ Test for missing authorization	Not Found
	Business Logic	
	✓ Test for feature misuse ✓ Test for lack of non-repudiation ✓ Test for trust relationships ✓ Test for integrity of data ✓ Test segregation of duties	Not Found
	Denial of Service	
	✓ Test for anti-automation ✓ Test for account lockout ✓ Test for HTTP protocol DoS ✓ Test for SQL wildcard DoS	Not Found
	Risky Functionality - File Uploads	
	✓ Test that file size limits, upload frequency and total file counts are defined and are enforced ✓ Test that file contents match the defined file type ✓ Test that all file uploads have Anti-Virus scanning in-place. Test that unsafe filenames are sanitized ✓ Test that uploaded files are not directly accessible within the web root ✓ Test that uploaded files are not served on the same hostname/port ✓ Test that files and other media are integrated with the authentication and authorization schemas	Not Found
	Risky Functionality - Card Payment	
	✓ Test for known vulnerabilities and configuration issues on Web Server and Web Application ✓ Test for default or guessable password ✓ Test for non-production data in live environment, and vice-versa ✓ Test for Injection vulnerabilities ✓ Test for Buffer Overflows ✓ Test for Insecure Cryptographic Storage ✓ Test for Insufficient Transport Layer Protection ✓ Test for Improper Error Handling	Not Found

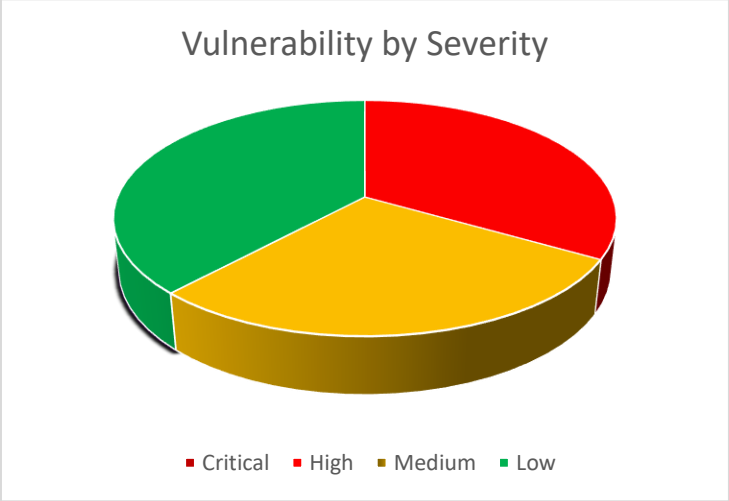
	✓ Test for all vulnerabilities with a CVSS v2 score > 4.0 ✓ Test for Authentication and Authorization issues ✓ Test for CSRF	
	Cryptography	
	✓ Check if data which should be encrypted is not ✓ Check for wrong algorithms usage depending on context ✓ Check for weak algorithms usage ✓ Check for proper use of salting ✓ Check for randomness functions	Not Found
	Secure Transmission	
	✓ Check SSL Version, Algorithms, Key length ✓ Check for Digital Certificate Validity (Duration, Signature and CN) ✓ Check credentials only delivered over HTTPS ✓ Check that the login form is delivered over HTTPS ✓ Check session tokens only delivered over HTTPS ✓ Check if HTTP Strict Transport Security (HSTS) in use	Not Found

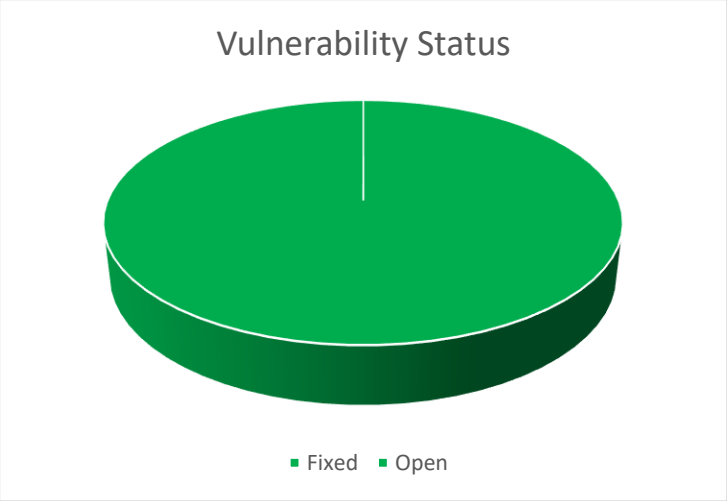
9.0 Test Execution Summary



10.0 Executive Summary:

Cybertryzub has been engaged by **Kiranovations Technologies Private Limited (Crego)** to undertake security testing against the **https://preprod.jupiter.crego.io** web application. The **Level 2** testing took place over the period from **05-09-2024** to **25-02-2025**. During this period the application was analyzed and assessed using a combination of standard tools and utilities and the knowledge and experience of our technical team. Although at the time of this engagement, the application was not in production, we nonetheless stopped short of undertaking specific tests that would either a) evidently risk the integrity and stability of the systems, or b) actively exploit potential vulnerabilities. Overall, we believe that a reasonable level of security has been attained by the applications that were the target of this test, but due to there being a high and some medium and low risk issues, remedial action needs to be carried out prior to official launch of the product. Testing revealed elements that are well-protected against several well-known vulnerabilities.





11.0 Summary of Vulnerabilities

Based on the assessment carried out by Cybertryzub from **05-09-2024** to **25-02-2025** following notable issues have been identified in reference to OWASP standards. This section provides a quick snapshot of the security posture for the Web Application.

S/N	Vulnerability	Severity	Level 1 – 23-07-2024	Closure – 25-02-2025
1	Stored XSS	High	OPEN	CLOSED*
2	Vulnerable TLS protocols detection	High	OPEN	CLOSED
3	Weak Cipher enabled	High	OPEN	CLOSED
4	Broken Access Control: Login via response manipulation	High	OPEN	CLOSED*
5	Business Logic Flaws: Accepting Negative values	High	OPEN	CLOSED
6	Business Logic Flaws: Line Expiry date can be set before Line activation date	High	OPEN	CLOSED
7	Session token does not expire	High	OPEN	CLOSED*
8	Application vulnerable to Lucky13 Attack	Medium	OPEN	CLOSED
9	Application vulnerable to BEAST Attack	Medium	OPEN	CLOSED
10	Application vulnerable to SWEET 32 Attack	Medium	OPEN	CLOSED
11	Improper Input Validation	Medium	OPEN	CLOSED*
12	Weak Password Policy	Medium	OPEN	CLOSED
13	DEBUG mode enabled	Medium	OPEN	CLOSED
14	Password Auto complete enabled	Low	OPEN	CLOSED
15	Clickjacking	Low	OPEN	CLOSED
16	No Captcha Implementation	Low	OPEN	CLOSED*
17	No Custom error page	Low	OPEN	CLOSED
18	Unwanted HTTP methods enabled	Low	OPEN	CLOSED
19	Missing Security Headers	Low	OPEN	CLOSED*
20	Concurrent Sessions	Low	OPEN	CLOSED*
21	Unencrypted Communication	Low	OPEN	CLOSED

12.0 Detailed Findings and Recommendation

12.1 Stored XSS

Severity	**High**
Status	**Closed*** As per client "Our web application has measures in place to prevent script execution. However, browsers may execute scripts beyond the application's control, which falls outside our boundary of responsibility."

Proof of Concept

12.2 Vulnerable TLS protocols detection

Severity	**High**
Status	**Closed**

Proof of Concept

Protocols	
TLS 1.3	Yes
TLS 1.2	Yes
TLS 1.1	No
TLS 1.0	No
SSL 3	No
SSL 2	No

Proof of Concept 12.2.1

12.3 Weak Ciphers Enabled

Severity	**High**
Status	**Closed**

Proof of Concept

Cipher Suites

 # TLS 1.3 (suites in server-preferred order)

TLS_AES_128_GCM_SHA256 (0x1301)	ECDH x25519 (eq. 3072 bits RSA) FS	128
TLS_AES_256_GCM_SHA384 (0x1302)	ECDH x25519 (eq. 3072 bits RSA) FS	256
TLS_CHACHA20_POLY1305_SHA256 (0x1303)	ECDH x25519 (eq. 3072 bits RSA) FS	256

 # TLS 1.2 (suites in server-preferred order)

TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 (0xc02f)	ECDH x25519 (eq. 3072 bits RSA) FS	128
TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 (0xc030)	ECDH x25519 (eq. 3072 bits RSA) FS	256
TLS_ECDHE_RSA_WITH_CHACHA20_POLY1305_SHA256 (0xcca8)	ECDH x25519 (eq. 3072 bits RSA) FS	256

Proof of Concept 12.3.1

12.4 Broken Access Control: Login via response manipulation

Severity	**High**
Status	**Closed*** As per client "This issue will be addressed as part of our Single Sign-On (SSO) implementation, which is scheduled for completion within the next 3 months."
Proof of Concept	

12.5 Business Logic Flaws: Accepting Negative values

Severity	High
Status	Closed

Proof of Concept

Request

Pretty Raw Hex JSON Web Tokens

```
PATCH /v1/lms/line_details/0560a37a-c470-4bfa-b23e-e10d28467f3b/ HTTP/2
Host: preprod.api.crego.io
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:136.0) Gecko/20100101 Firefox/136.0
Accept: application/json
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Content-Type: application/json
X-App-Name: Jupiter
Authorization: Bearer
eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ0b2tlbl90eXBlIjoiYWNjZXNzIiwiZXhwIjoxNzQwMzAzNDAzLCJpYXQiOjE3ND
AyOTk4MDMsImp0aSI6IjM0MzNlNzBiZWM5ODRiMTdiOGYyMTI2ZTZkNTcxZDAzIiwidXNlcl9pZCI6IjZkYTA4NDAxLWIxZjctNDZlY
y05MDEzLTJhOWQ3YmM2MTg1YyIsImNvbXBhbnlfaWQiOiIyMzA2N2RiYy02YzYyLTQyMDMtOTAxNC03MTAwZTRmZmU4MTEiLCJ1c2Vy
bmFtZSI6ImFkYW5pX2FkbWluIiwiYWNjZXNzX3R5cGUiOiJqdXBpdGVyIiwidHlwZSI6ImxlbmRlciIsInJvbGVzIjpbIlNhbGVzICh
EZWZhdWx0KSIsIkNyZWRpdCAoRGVmYXVsdCkiLCJEaXNidXJzYWwgT1BzIChEZWZhdWx0KSIsIlBheW91dCBDaGVja2VyIChEZWZhdW
x0KSIsIlJlcGF5bWVudCBNYWtlciAoRGVmYXVsdCkiXX0.oBiXcPNKZmjruaEC3uj0dDZx-YHQS43VJrSzoBNFEcY
Ngrok-Skip-Browser-Warning: true
Content-Length: 277
Origin: https://preprod.jupiter.crego.io
Sec-Fetch-Dest: empty
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-site
Priority: u=0
Te: trailers

{"line_activation_date":1733769000,"line_expiry_date":1736447400,"type":"program","program_id":
"2a3094cc-a266-4293-9e4a-31e7bbad3518","approved_line_amount":-1000,"operative_line_amount":-1000,
"is_max_active_drawdowns":false,"max_active_drawdowns":0,"active_line_amount":-1000}
```

Response

Pretty Raw Hex Render

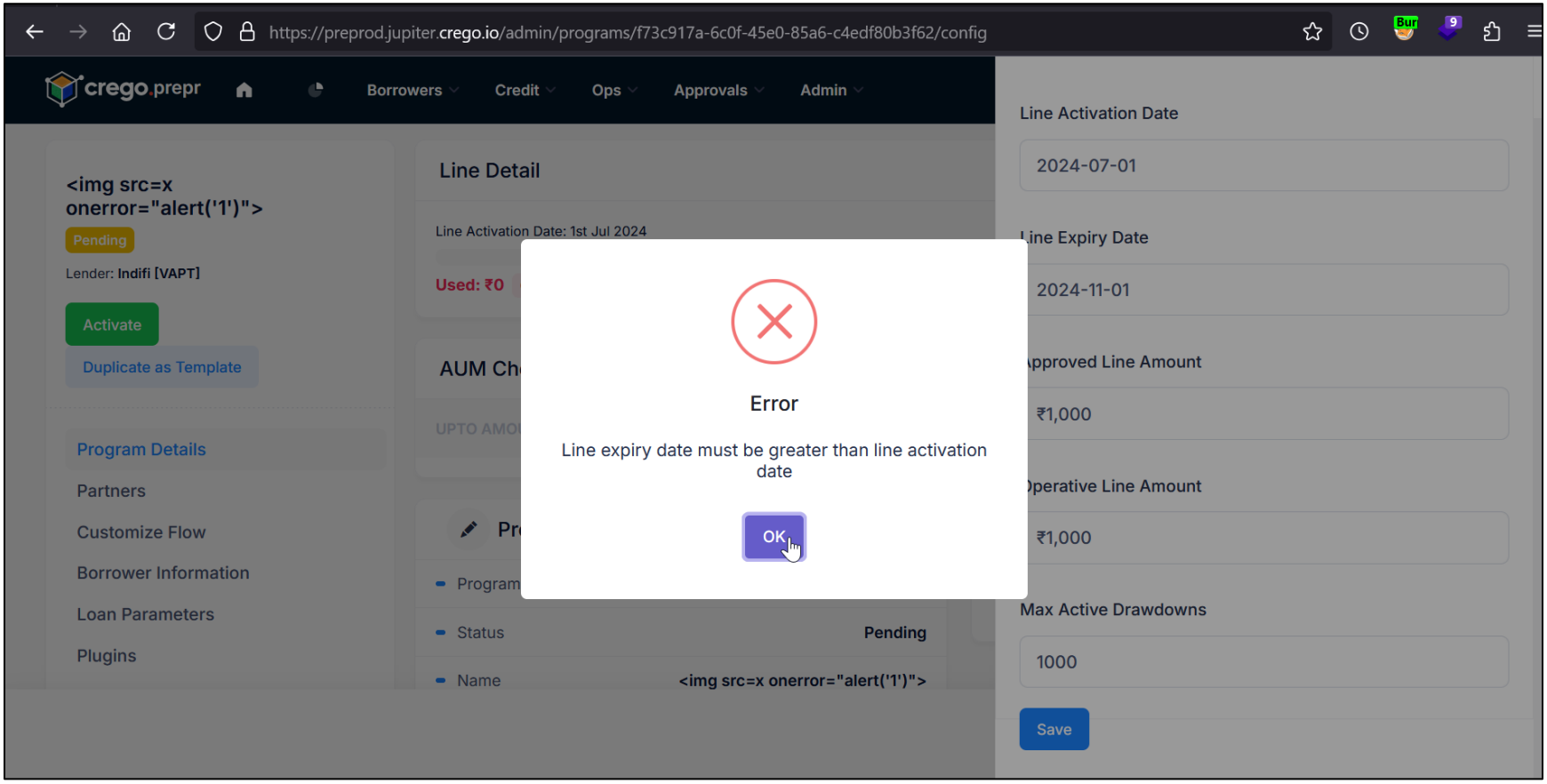
```
HTTP/2 400 Bad Request
Date: Sun, 23 Feb 2025 08:45:55 GMT
Content-Type: application/json
Content-Length: 59
Server: gunicorn
Set-Cookie: AWSALB=
VhblC2FHAM3G1lSktSzI2x4r9I2p04VJkkqej7kZ15qw1QZcERInRxOOpngP08xktyeipiq6Kog
2bN72iCzlq8GyjhGuwBJVsk4C8UaK3C4Ok9vkjlneV8BTKGrk; Expires=Sun, 02 Mar 2025
 08:45:55 GMT; Path=/
Set-Cookie: AWSALBCORS=
VhblC2FHAM3G1lSktSzI2x4r9I2p04VJkkqej7kZ15qw1QZcERInRxOOpngP08xktyeipiq6Kog
2bN72iCzlq8GyjhGuwBJVsk4C8UaK3C4Ok9vkjlneV8BTKGrk; Expires=Sun, 02 Mar 2025
 08:45:55 GMT; Path=/; SameSite=None
Allow: GET, PUT, PATCH, HEAD, OPTIONS
Vary: origin
X-Content-Type-Options: nosniff
Referrer-Policy: same-origin
Cross-Origin-Opener-Policy: same-origin
Access-Control-Allow-Origin: https://preprod.jupiter.crego.io
Access-Control-Expose-Headers: content-disposition
Apigw-Requestid: Gbf6ninehcwEJlA=

{"message":"Approved line amount shall not be less than 0"}
```

Proof of Concept 12.5.1

12.6 Business Logic Flaws: Line Expiry date can be set before Line Activation date

Severity	**High**
Status	**Closed**

Proof of Concept



Proof of Concept 12.6.1

12.7 Session token does not expire after logout

Severity	**High**
Status	**Closed*** As per client "This will be resolved with the upcoming SSO implementation, planned for release within the next 3 months."
Proof of Concept	

12.8 Application vulnerable to Lucky13 Attack

Severity	Medium
Status	Closed

Proof of Concept

```
 Testing vulnerabilities

 Heartbleed (CVE-2014-0160)                not vulnerable (OK), no heartbeat extension
 CCS (CVE-2014-0224)                       not vulnerable (OK)
 Ticketbleed (CVE-2016-9244), experiment.  not vulnerable (OK), no session tickets
 ROBOT                                     Server does not support any cipher suites that use RSA key transport
 Secure Renegotiation (RFC 5746)           supported (OK)
 Secure Client-Initiated Renegotiation     likely not vulnerable (OK), timed out
 CRIME, TLS (CVE-2012-4929)                not vulnerable (OK)
 BREACH (CVE-2013-3587)                    no gzip/deflate/compress/br HTTP compression (OK)  - only supplied "/" tested
 POODLE, SSL (CVE-2014-3566)               not vulnerable (OK), no SSLv3 support
 TLS_FALLBACK_SCSV (RFC 7507)              No fallback possible (OK), no protocol below TLS 1.2 offered
 SWEET32 (CVE-2016-2183, CVE-2016-6329)    not vulnerable (OK)
 FREAK (CVE-2015-0204)                     not vulnerable (OK)
 DROWN (CVE-2016-0800, CVE-2016-0703)      not vulnerable on this host and port (OK)
                                           make sure you don't use this certificate elsewhere with SSLv2 enabled services, see
                                           https://search.censys.io/search?resource=hosts&virtual_hosts=INCLUDE&q=4F3612E769A6DF02E0F0DC0E76EC4A6AD703A8BB82E89F6FC2F018B9DA3E6ECF
 LOGJAM (CVE-2015-4000), experimental      not vulnerable (OK): no DH EXPORT ciphers, no DH key detected with ≤ TLS 1.2
 BEAST (CVE-2011-3389)                     not vulnerable (OK), no SSL3 or TLS1
 LUCKY13 (CVE-2013-0169), experimental     not vulnerable (OK)
 Winshock (CVE-2014-6321), experimental    not vulnerable (OK)
 RC4 (CVE-2013-2566, CVE-2015-2808)        no RC4 ciphers detected (OK)
```

Proof of Concept 12.8.1

12.9 Application vulnerable to BEAST Attack

Severity	**Medium**
Status	**Closed**

Proof of Concept

```
 Testing vulnerabilities

 Heartbleed (CVE-2014-0160)                not vulnerable (OK), no heartbeat extension
 CCS (CVE-2014-0224)                       not vulnerable (OK)
 Ticketbleed (CVE-2016-9244), experiment.  not vulnerable (OK), no session tickets
 ROBOT                                     Server does not support any cipher suites that use RSA key transport
 Secure Renegotiation (RFC 5746)           supported (OK)
 Secure Client-Initiated Renegotiation     likely not vulnerable (OK), timed out
 CRIME, TLS (CVE-2012-4929)                not vulnerable (OK)
 BREACH (CVE-2013-3587)                    no gzip/deflate/compress/br HTTP compression (OK)  - only supplied "/" tested
 POODLE, SSL (CVE-2014-3566)               not vulnerable (OK), no SSLv3 support
 TLS_FALLBACK_SCSV (RFC 7507)              No fallback possible (OK), no protocol below TLS 1.2 offered
 SWEET32 (CVE-2016-2183, CVE-2016-6329)    not vulnerable (OK)
 FREAK (CVE-2015-0204)                     not vulnerable (OK)
 DROWN (CVE-2016-0800, CVE-2016-0703)      not vulnerable on this host and port (OK)
                                           make sure you don't use this certificate elsewhere with SSLv2 enabled services, see
                                           https://search.censys.io/search?resource=hosts&virtual_hosts=INCLUDE&q=4F3612E769A6DF02E0F0DC0E76EC4A6AD703A8BB82E89F6FC2F018B9DA3E6ECF
 LOGJAM (CVE-2015-4000), experimental      not vulnerable (OK): no DH EXPORT ciphers, no DH key detected with ≤ TLS 1.2
 BEAST (CVE-2011-3389)                     not vulnerable (OK), no SSL3 or TLS1
 LUCKY13 (CVE-2013-0169), experimental     not vulnerable (OK)
 Winshock (CVE-2014-6321), experimental    not vulnerable (OK)
 RC4 (CVE-2013-2566, CVE-2015-2808)        no RC4 ciphers detected (OK)
```

Proof of Concept 12.9.1

12.10 Application vulnerable to SWEET32 Attack

Severity	**Medium**
Status	**Closed**

Proof of Concept

```
 Testing vulnerabilities

 Heartbleed (CVE-2014-0160)                not vulnerable (OK), no heartbeat extension
 CCS (CVE-2014-0224)                       not vulnerable (OK)
 Ticketbleed (CVE-2016-9244), experiment.  not vulnerable (OK), no session tickets
 ROBOT                                     Server does not support any cipher suites that use RSA key transport
 Secure Renegotiation (RFC 5746)           supported (OK)
 Secure Client-Initiated Renegotiation     likely not vulnerable (OK), timed out
 CRIME, TLS (CVE-2012-4929)                not vulnerable (OK)
 BREACH (CVE-2013-3587)                    no gzip/deflate/compress/br HTTP compression (OK)  - only supplied "/" tested
 POODLE, SSL (CVE-2014-3566)               not vulnerable (OK), no SSLv3 support
 TLS FALLBACK SCSV (RFC 7507)              No fallback possible (OK), no protocol below TLS 1.2 offered
 SWEET32 (CVE-2016-2183, CVE-2016-6329)    not vulnerable (OK)
 FREAK (CVE-2015-0204)                     not vulnerable (OK)
 DROWN (CVE-2016-0800, CVE-2016-0703)      not vulnerable on this host and port (OK)
                                           make sure you don't use this certificate elsewhere with SSLv2 enabled services, see
                                           https://search.censys.io/search?resource=hosts&virtual_hosts=INCLUDE&q=4F3612E769A6DF02E0F0DC0E76EC4A6AD703A8BB82E89F6FC2F018B9DA3E6ECF
 LOGJAM (CVE-2015-4000), experimental      not vulnerable (OK): no DH EXPORT ciphers, no DH key detected with ≤ TLS 1.2
 BEAST (CVE-2011-3389)                     not vulnerable (OK), no SSL3 or TLS1
 LUCKY13 (CVE-2013-0169), experimental     not vulnerable (OK)
 Winshock (CVE-2014-6321), experimental    not vulnerable (OK)
 RC4 (CVE-2013-2566, CVE-2015-2808)        no RC4 ciphers detected (OK)
```

Proof of Concept 12.10.1

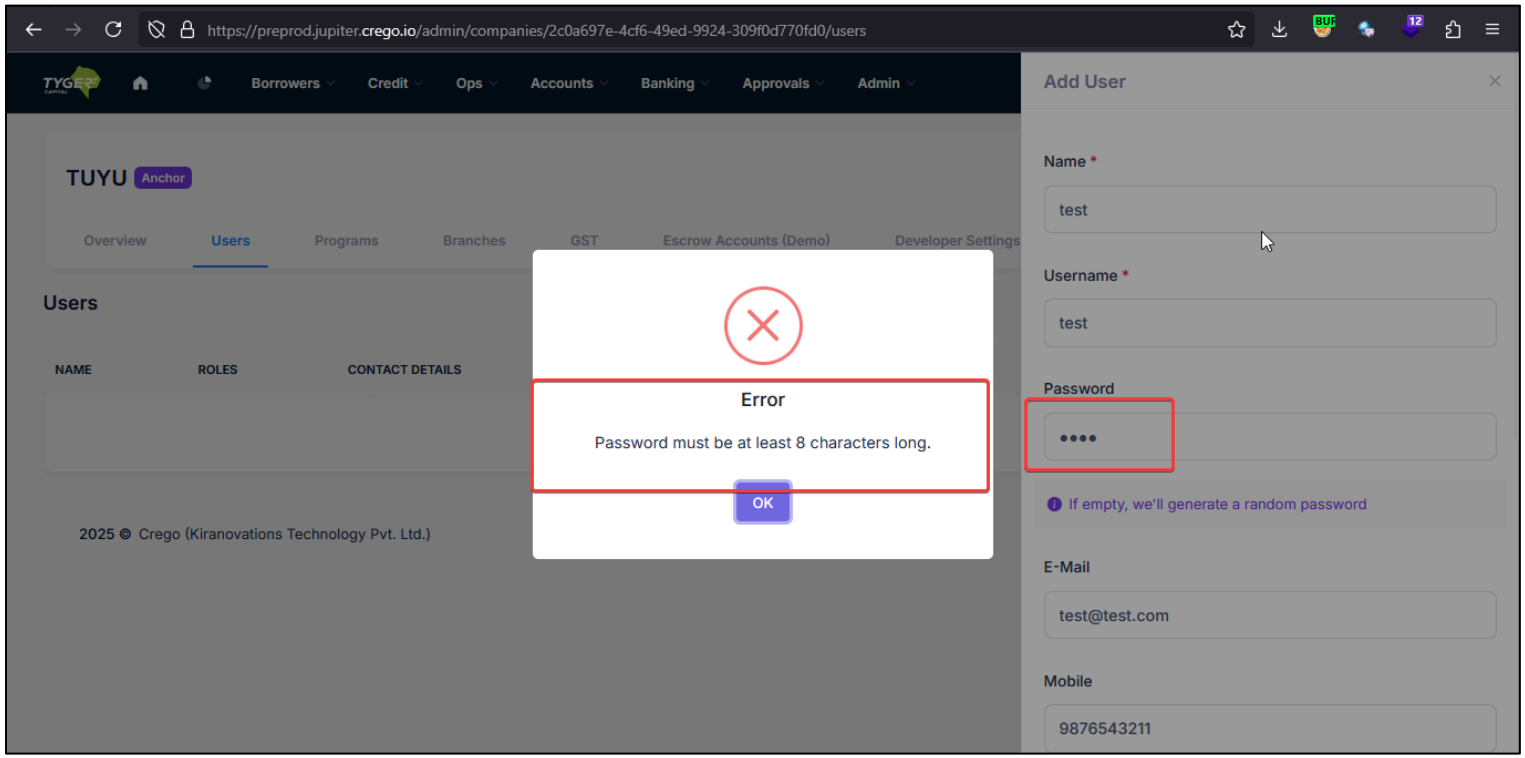
12.11 Improper Input Validation

Severity	**Medium**
Status	**Closed*** As per client "We have intentionally kept certain fields open for flexibility. Input validations are being gradually introduced as part of our ongoing development efforts."
Proof of Concept	

12.12 Weak Password Policy

Severity	Medium
Status	Closed

Proof of Concept



Proof of Concept 12.12.1

12.13 DEBUG mode accessible

Severity	Medium
Status	Closed

Proof of Concept

Request

Pretty Raw Hex JSON Web Tokens

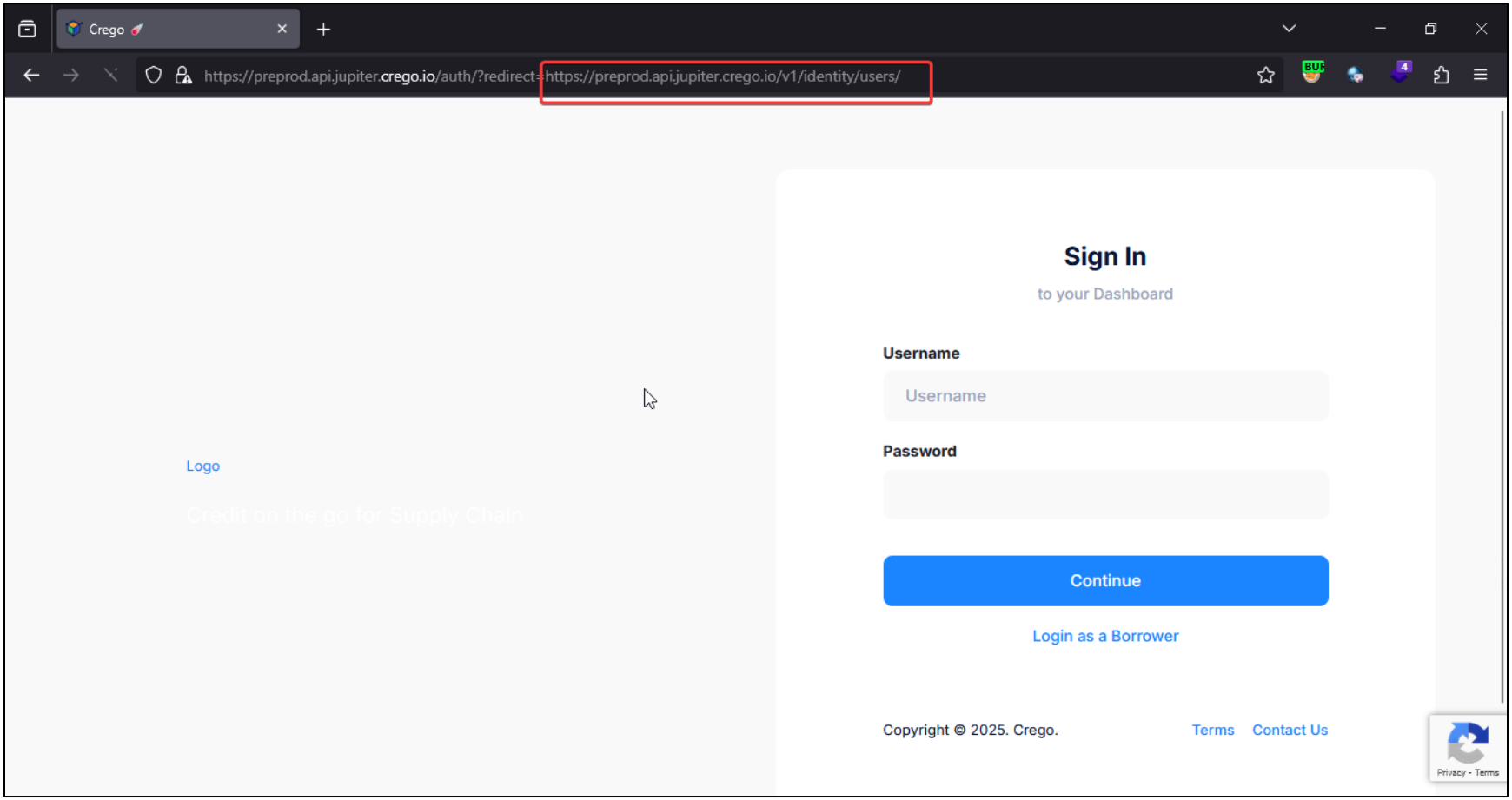
```
GET /v1/lms/approvals/?expand=borrower%2Crole%2Ccompany%2Ctopup%2Cprogram&type=
a'a%5c'b%22c%3e%3f%3e%25%7d%7d%25%25%3ec%3c[[%3f$%7b%7b%25%7d%7dcake%5c&status=pending&
tab=mine HTTP/2
Host: preprod.api.crego.io
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:129.0) Gecko/20100101
Firefox/129.0
Accept: application/json
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
X-App-Name: Jupiter
Authorization: Bearer
eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ0b2tlbl90eXBlIjoiYWNjZXNzIiwiZXhwIjoxNzIyNTA3MjU5
LCJpYXQiOjE3MjIyNDgwNTksImp0aSI6ImFlYWY3ZjZiOWQzYTQ1MjU5NTBmYzA0ZTE1ZTQ3MWJiIiwidXNlcl9pZ
CI6ImE3YzE1ODAzLTg1MzUtNDc4OC1hNmU3LTNjMzVlNjhkMzI0MCIsImNvbXBhbnlfaWQiOiIxNWMzOTg4Ni1hMD
RlLTQ5ZWYtODQ1Zi05Y2Q5YzM0ZjFjNjIiLCJ1c2VybmFtZSI6ImluZGlmaV9hZG1pbiIsImFjY2Vzc190eXBlIjo
ianVwaXRlciIsInR5cGUiOiJsZW5kZXIifQ.sIi3T6zKtCf94N3rkuX7WKKv5vWbmbmyZtO_rm5CNIg
Ngrok-Skip-Browser-Warning: true
Origin: https://preprod.jupiter.crego.io
Referer: https://preprod.jupiter.crego.io/
Sec-Fetch-Dest: empty
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-site
Te: trailers
```

Response

Pretty Raw Hex Render

```
HTTP/2 403 Forbidden
Date: Fri, 21 Feb 2025 05:09:47 GMT
Content-Type: application/json
Content-Length: 23
Access-Control-Allow-Origin: https://preprod.jupiter.crego.io
Vary: origin
Access-Control-Expose-Headers: content-disposition
Apigw-Requestid: GUaYVjnohcwEM6A=

{
    "message":"Forbidden"
}
```

Proof of Concept 12.13.1



Proof of Concept 12.13.2

Request

Pretty Raw Hex

```
POST /v1/identity/auth/borrower/send_otp/ HTTP/2
Host: preprod.api.crego.io
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:136.0)
Gecko/20100101 Firefox/136.0
Accept: application/json
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Content-Type: application/json
X-App-Name: Jupiter
Content-Length: 35
Origin: https://preprod.jupiter.crego.io
Sec-Fetch-Dest: empty
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-site
Priority: u=0
Te: trailers

{
    "mobile":9876543211,
    "bypass":true
}
```

Response

Pretty Raw Hex Render

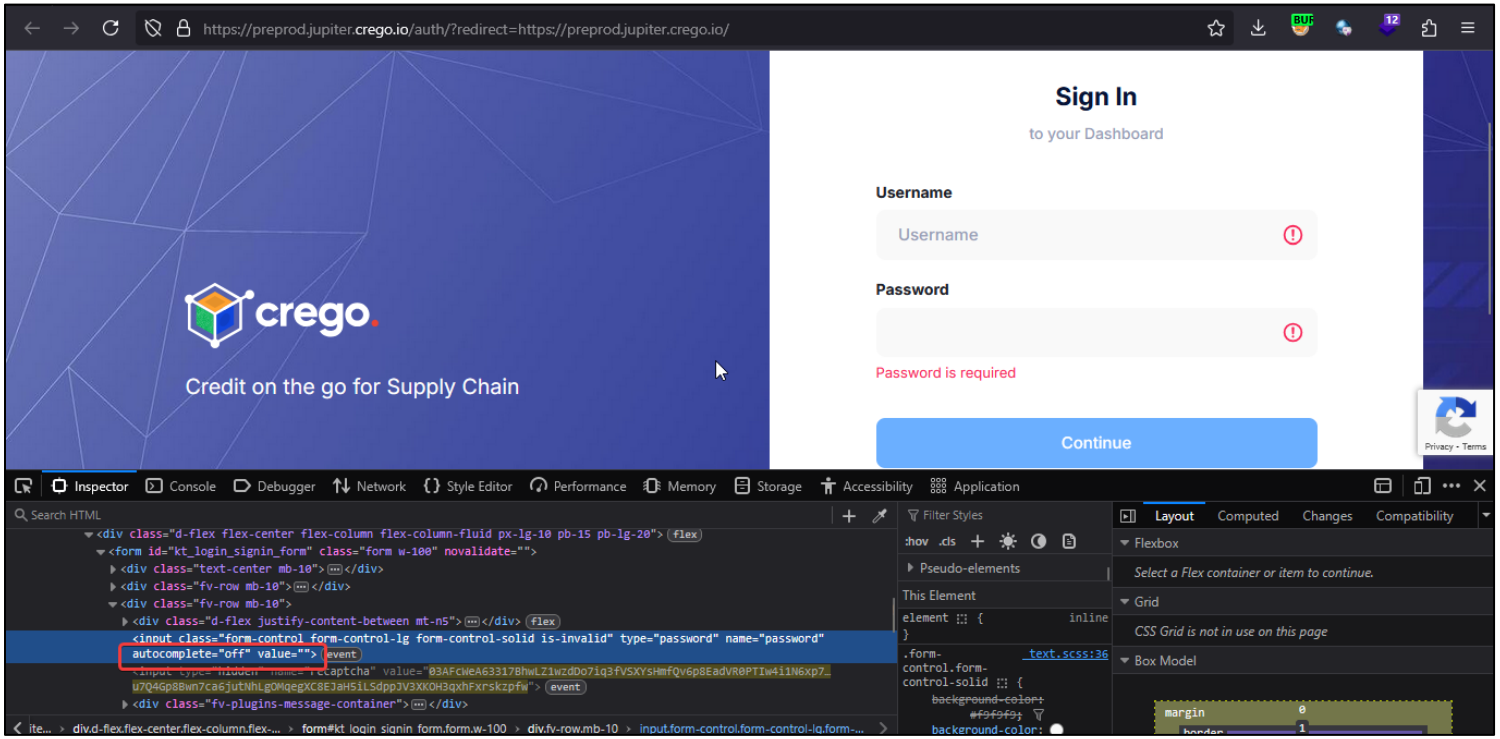
```
HTTP/2 400 Bad Request
Date: Fri, 21 Feb 2025 05:07:43 GMT
Content-Type: application/json
Content-Length: 110
Server: gunicorn
Set-Cookie: AWSALB=
cn0l19k39ts7fpiIMSba1WK4gu6TR5J2V/oM0Sjk1OyDz4HUBn3FeslCSBQ+eNoiS3AY/cJ2rtD4L5HjDdtgewbILV8gL9aJgS2y
mtb+go3/mPqHDwtFVFqrU1w0; Expires=Fri, 28 Feb 2025 05:07:43 GMT; Path=/
Set-Cookie: AWSALBCORS=
cn0l19k39ts7fpiIMSba1WK4gu6TR5J2V/oM0Sjk1OyDz4HUBn3FeslCSBQ+eNoiS3AY/cJ2rtD4L5HjDdtgewbILV8gL9aJgS2y
mtb+go3/mPqHDwtFVFqrU1w0; Expires=Fri, 28 Feb 2025 05:07:43 GMT; Path=/; SameSite=None
Allow: POST, OPTIONS
Vary: origin
X-Content-Type-Options: nosniff
Referrer-Policy: same-origin
Cross-Origin-Opener-Policy: same-origin
Access-Control-Allow-Origin: https://preprod.jupiter.crego.io
Access-Control-Expose-Headers: content-disposition
Apigw-Requestid: GUaE_h9lBcwEPVw=

{"message":"No account found, provide program id to create a new account","status_code":
"PROGRAM_ID_REQUIRED"}
```

Proof of Concept 12.13.3

12.14 Password Auto complete enabled

Severity	Medium
Status	Closed

Proof of Concept

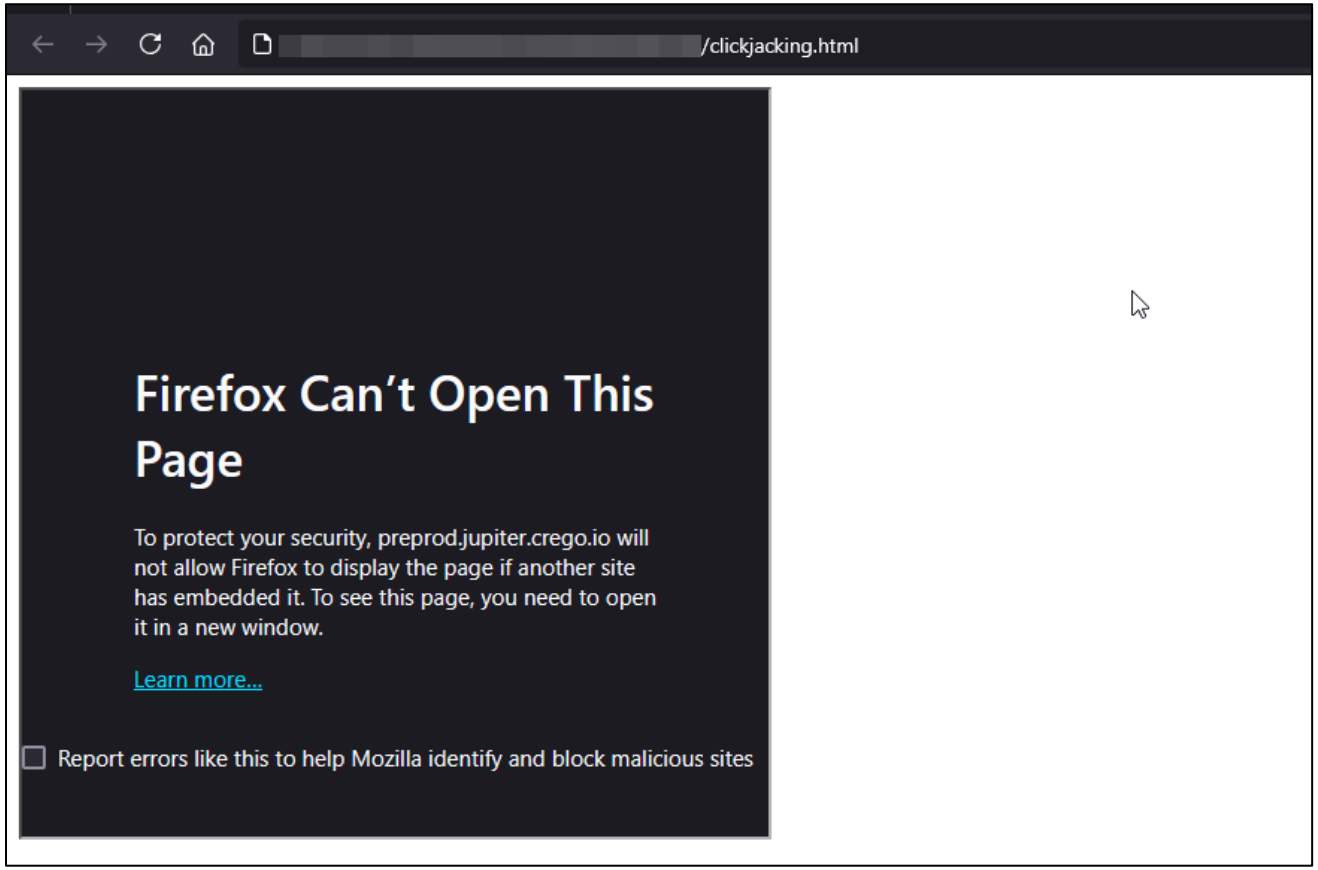


Proof of Concept 12.14.1

12.15 Clickjacking

Severity	Low
Status	Closed

Proof of Concept



Proof of Concept 12.15.1

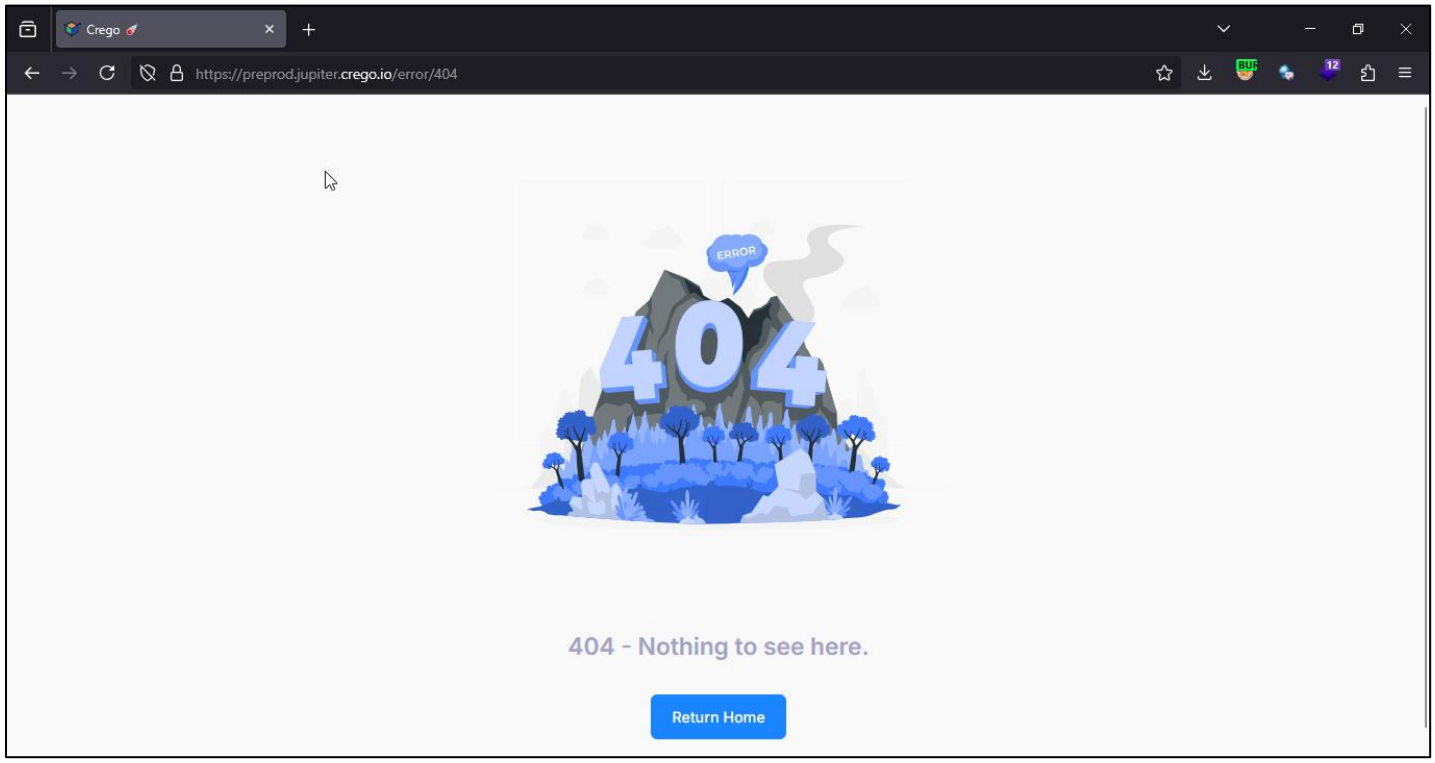
12.16 No captcha Implementation

Severity	**Low**
Status	**Closed*** As per client "Business requirement to not implement captacha, instead we will implement MFA"
Proof of Concept	

12.17 Missing custom error page

Severity	Low
Status	Closed

Proof of Concept



Proof of Concept 12.14.1

12.18 Unwanted HTTP methods enabled

Severity	**Low**
Status	**Closed**

Proof of Concept

Request

Pretty Raw Hex

```
POST / HTTP/2
Host: preprod.jupiter.crego.io
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:136.0) Gecko/20100101
Firefox/136.0
Accept: image/avif,image/webp,image/png,image/svg+xml,image/*;q=0.8,*/*;q=0.5
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Referer: https://preprod.jupiter.crego.io/auth/login/
Sec-Fetch-Dest: image
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-origin
Priority: u=5, i
Te: trailers
Content-Type: application/x-www-form-urlencoded
Content-Length: 0
```

Response

Pretty Raw Hex Render

```
HTTP/2 200 OK
Content-Type: text/html
Content-Length: 1620
Last-Modified: Fri, 14 Feb 2025 10:11:59 GMT
X-Amz-Server-Side-Encryption: AES256
Accept-Ranges: bytes
Server: AmazonS3
Date: Thu, 20 Feb 2025 06:25:57 GMT
Etag: "c22d8ca878e7fa425c1b7af663d9fd40"
X-Cache: Error from cloudfront
Via: 1.1 e922f68baf39b36844fe5c5e357acbc2.cloudfront.net (CloudFront)
X-Amz-Cf-Pop: MRS52-C1
X-Amz-Cf-Id: 6sxgosd8VedB5Vokzn-cR-yxpeIjEySqG7PJLYmxsWJn1Ty8h66I3Q==
Age: 43400
X-Xss-Protection: 1
X-Frame-Options: SAMEORIGIN
Referrer-Policy: same-origin
X-Content-Type-Options: nosniff
Strict-Transport-Security: max-age=31536000; includeSubDomains; preload
Vary: Origin

<!doctype html><html lang="en">
```

Proof of Concept 12.18.1

12.19 Missing Security Header

Severity	**Low**
Status	**Closed*** As per client "We are in the process of implementing a robust Content Security Policy (CSP) to mitigate risks associated with unauthorized script execution. This will be part of our upcoming security enhancements and is scheduled for deployment in the next release cycle."
Proof of Concept	

12.20 Concurrent Sessions

Severity	**Low**
Status	**Closed*** As per client "Business Requirement"
Proof of Concept	

12.21 Unencrypted Communication

Severity	Low
Status	Closed

Proof of Concept

Send | Cancel | Follow redirection | Target: http://preprod.jupiter.crego.io | HTTP/1

Request

Pretty | Raw | Hex

```
GET / HTTP/1.1
Host: preprod.jupiter.crego.io
Cookie: _ga_QRH4W6XQGB=GS1.1.1740075887.11.1.1740076277.0.0.0; _ga=GA1.1.1559598166.1739182182
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:136.0) Gecko/20100101 Firefox/136.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Referer: https://preprod.jupiter.crego.io/logout
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Sec-Fetch-User: ?1
Priority: u=0, i
Te: trailers
```

Response

Pretty | Raw | Hex | Render

```
HTTP/1.1 301 Moved Permanently
Server: CloudFront
Date: Thu, 20 Feb 2025 18:40:16 GMT
Content-Type: text/html
Content-Length: 167
Connection: keep-alive
Location: https://preprod.jupiter.crego.io/
X-Cache: Redirect from cloudfront
Via: 1.1 4a0cc1ef0dc7ada28fa94de0447121fe.cloudfront.net (CloudFront)
X-Amz-Cf-Pop: MRS52-C1
X-Amz-Cf-Id: 5UstGqrNyfW4zsFG5qeSviPSY9gDS3xo6oLie8oogzio4Yr-AjsmRg==
X-XSS-Protection: 1
X-Frame-Options: SAMEORIGIN
Referrer-Policy: same-origin
X-Content-Type-Options: nosniff
Vary: Origin

<html>
    <head>
        <title>
            301 Moved Permanently
        </title>
    </head>
```

Proof of Concept 12.21.1

13.0 High-Level Recommendations

Taking into consideration all issues that have been discovered, we highly recommend to:

- Conduct current vs. future IT/Security program review
- Conduct Static code analysis for codebase
- Establish Secure SDLC best practices, assign Security Engineer to a project to monthly review code, conduct SAST & DAST security testing
- Review Architecture of application
- Deploy Web Application Firewall solution to detect any malicious manipulations
- Continuously monitor logs for anomalies to detect abnormal behavior and fraud transactions. Dedicate security operations engineer to this task
- Implement Patch Management procedures for whole IT infrastructure and endpoints of employees and developers
- Continuously Patch production and development environments and systems on regular bases with latest releases and security updates
- Conduct annual Penetration test and quarterly Vulnerability Scanning against internal and external environment
- Develop and Conduct Security Awareness training for employees and developers
- Develop Incident Response Plan in case of Data breach or security incidents
- Analyze risks for key assets and resources
- Update codebase to conduct verification and sanitization of user input on both, client and server side
- Use only encrypted channels for communications
- Do not send any unnecessary data in requests and cookies
- Improve server and application configuration to meet security best practices

Shubham Raj Mourya

Digitally signed by Shubham Raj Mourya
Date: 2025.03.01 22:54:49 +05'30'